

# Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-10 16:55 WIB

## Top 5 Highlights

- Dormant GitHub Accounts Help Attackers Blend In While Mapping Corporate Orgs
- New GigaWiper Windows Backdoor Bundles Disk Wiping, Fake Ransomware, and Spyware
- New Helix vishing group emerges in SharePoint data theft attacks
- VU#152953: PayRange Android app version 7.0.7 contains multiple vulnerabilities
- npm 12 Disables Install Scripts by Default to Reduce Supply Chain Risk

# Threat Intelligence (10)

## 01. Dormant GitHub Accounts Help Attackers Blend In While Mapping Corporate Orgs

Datadog Security Labs is warning of "several overlapping campaigns" that are systematically enumerating corporate GitHub organizations, repositories, and user accounts through the GitHub API. "Operators rely on automated scraping tooling with custom or legitimate-sounding user agents, leveraging GitHub 'ghost' accounts that are often years old, or compromis...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/dormant-github-accounts-help-attackers.html>

## 02. npm 12 Disables Install Scripts by Default to Reduce Supply Chain Risk

GitHub has officially announced the release of npm version 12 with install scripts disabled by default, along with deprecating granular access tokens (GATs) designed to bypass two-factor authentication (2FA). The Microsoft-owned subsidiary noted that the following npm install behaviors that used to run automatically before have been made opt-in - allowScrip...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/07/npm-12-disables-install-scripts-by.html>

## 03. Rethinking Email Security in the AI Era How Modern Phishing Bypasses Traditional SEGs - WC #1

Rethinking Email Security in the AI Era How Modern Phishing Bypasses Traditional SEGs - WC #1

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/podcast-segment/15358-rethinking-email-security-in-the-ai-era-how-modern-phishing-bypasses-traditional-segs-wc-1>

## 04. GigaWiper: Anatomy of a destructive backdoor assembled from multiple malware

GigaWiper is a destructive backdoor that combines multiple wiping and ransomware-like capabilities into a single operational platform. This blog analyzes how the malware incorporates code from several previously separate malware families and provides guidance to help defenders detect and defend against similar threats. The post

## GigaWiper: Anatomy of a destr...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/07/09/gigawiper-anatomy-of-a-destructive-backdoor-assembled-from-multiple-malware/>

## 05. New Forg365 phishing platform uses AI to target Microsoft 365 accounts

A new phishing-as-a-service (PhaaS) operation called Forg365 focuses on stealing Microsoft 365 accounts by combining adversary-in-the-middle (AiTM) and device code methods with AI-assisted lure generation. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/new-forg365-phishing-platform-uses-ai-to-target-microsoft-365-accounts/>

## 06. Vibe-Coded Malware Caught in Active Directory Attack

Huntress found a threat actor using vibe-coded PowerShell to map an Active Directory network

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/vibe-coded-malware-ai-powershell/>

## 07. Attack on Amazon Bedrock-linked AI gateway highlights new cloud security risk

A cloud intrusion that ended with the deployment of cryptomining malware has exposed a bigger risk for enterprises: AI gateways that concentrate access to cloud identities, permissions, and foundation models in a single, highly privileged system. Researchers from cybersecurity firm Darktrace found attackers compromising an AWS EC2 instance acting as a LiteL...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoonline.com/article/4194984/attack-on-amazon-bedrock-linked-ai-gateway-highlights-new-cloud-security-risk.html>

## 08. US Threat Landscape Alert: 30 Active Malware Families Ranked by Real Sandbox Data

State of Cybersecurity in the US American organizations are processing more malware submissions than ever, and the mix keeps shifting under their feet. Phishing kits that hijack multi-factor authentication now sit alongside decades-old ransomware, commodity RATs sold for the price of a streaming subscription, and loaders built to slip payloads past EDR unde...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://any.run/cybersecurity-blog/usa-top-30-threats-2026/>

## 09. [+24h Old] AWS centralizes access, spending, and governance for Claude

Claude apps gateway for AWS is a self-hosted control plane that gives organizations a single point of control over access, costs, and policies for Claude Code and Claude Desktop. It replaces per-developer cloud credentials, manual distribution of managed settings to developer laptops, and centralizes usage attribution and spending controls. The gateway can...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/07/09/aws-claude-apps-gateway-governance/>

## 10. [+24h Old] Fake 7-Zip Installers Turn Devices Into Residential Proxy Nodes

Cybersecurity researchers have disclosed details of a new threat actor dubbed Lurking Lizard that has been operating an end-to-end malicious residential proxy business using an infrastructure comprising more than 230 lookalike domains. The activity dates back to at least August 2022, according to DNS threat intelligence firm Infoblox. Once such campaign, ob...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/fake-7-zip-installers-turn-devices-into.html>

# Latest Vulnerabilities (10)

## 01. VU#152953: PayRange Android app version 7.0.7 contains multiple vulnerabilities

Overview PayRange is a mobile payment app that allows users to pay for vending machines, laundromats, and other unattended machines using a smartphone with Bluetooth. Two vulnerabilities were discovered in version 7.0.7 of the PayRange app that is available in the Google Play store. Description A vulnerability (CVE-2026-13462) exists in the PayRange Android...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/152953>

## 02. Palo Alto Networks Patches 13 Vulnerabilities

Buffer overflow, DoS, command injection, SSRF, authentication bypass, and other types of vulnerabilities have been found in PAN-OS software. The post Palo Alto Networks Patches 13 Vulnerabilities appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/palo-alto-networks-patches-13-vulnerabilities/>

## 03. Microsoft closes book on Nightmare Eclipse's RoguePlanet zero-day

Weeks after the exploit code dropped, Redmond has finally ships a fix for the Defender zero-day

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/07/09/microsoft-closes-book-on-nightmare-eclipses-rogueplanet-zero-day/5269280>

## 04. VU#734812: Xerte Online Toolkit contains an authentication bypass that allows for RCE

Overview Two vulnerabilities have been discovered in Xerte Online Toolkits, an open-source e-learning authoring toolsuite intended for the creation of learning materials within a web browser. CVE-2026-14261 tracks the persistence of the /setup/ directory after installation, which allows an unauthenticated attacker to reconfigure the application to point to...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/734812>

## 05. UK cyber agency unveils AI-powered Cyber Shield to counter attacks at machine speed

The UK's National Cyber Security Centre (NCSC) wants to deploy autonomous AI agents capable of finding and neutralizing cyberattacks on national networks in real time, marking Britain's push toward a sovereign, machine-speed cyber defense system. The

blueprint, called Cyber Shield, was developed jointly with the Department for Science, Innovation and Techno...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4194997/uk-cyber-agency-unveils-ai-powered-cyber-shield-to-counter-attacks-at-machine-speed.html>

## 06. 12 Million Impacted by Data Breach at Japanese Telco KDDI

Hackers exploited a zero-day vulnerability in a third-party system to access a KDDI email system for ISPs. The post 12 Million Impacted by Data Breach at Japanese Telco KDDI appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/12-million-impacted-by-data-breach-at-japanese-telco-kddi/>

## 07. Microsoft releases fix for RoguePlanet Defender flaw (CVE-2026-50656)

Microsoft has finally released a security update for its Microsoft Malware Protection Engine, which fixes CVE-2026-50656, the Windows Defender local privilege escalation vulnerability triggered by the RoguePlanet exploit. The vulnerability and the fix CVE-2026-50656 is due to improper link resolution before file access, affects Windows 10 and Windows 11, an...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/09/microsoft-releases-fix-for-rogueplanet-defender-flaw-cve-2026-50656/>

## 08. 15-Year-Old Linux Vulnerability 'GhostLock' Earns Researchers \$92k From Google

Affecting every major distribution since 2011, the Linux kernel vulnerability allows attackers to gain root access. The post 15-Year-Old Linux Vulnerability 'GhostLock' Earns Researchers \$92k From Google appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/15-year-old-linux-vulnerability-ghostlock-earns-researchers-92k-from-google/>

## 09. Microsoft Patches Defender 'RoguePlanet' Vulnerability

The privilege escalation vulnerability tracked as CVE-2026-50656 has been patched with a Microsoft Malware Protection Engine update. The post Microsoft Patches Defender 'RoguePlanet' Vulnerability appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/microsoft-patches-defender-rogueplanet-vulnerability/>

## 10. Agentic AI identity: A 6-stage maturity model for non-human identities

In a client engagement last year, an LLM-based deployment agent with standing access to a production Kubernetes cluster triggered a four-hour outage through a malformed configuration push. In the IAM, the agent appeared as a service account with a long-lived API key, no MFA, no scoped revocation path. When the incident review team asked which human had auth...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4194548/agentic-ai-identity-a-6-stage-maturity-model-for-non-human-identities.html>

# Data Breach & Cybercrime (10)

## 01. New GigaWiper Windows Backdoor Bundles Disk Wiping, Fake Ransomware, and Spyware

Microsoft has taken apart a destructive Windows backdoor it calls GigaWiper. What stands out is how it is built: not one tool but three older destructive programs bolted into one, offered as commands the operator can choose from. Each is a different way to break a machine: wipe the whole disk, overwrite the Windows drive, or run fake "ransomware" that scram...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://thehackernews.com/2026/07/new-gigawiper-windows-backdoor-bundles.html>

## 02. New Helix vishing group emerges in SharePoint data theft attacks

A new data-extortion group called Helix is using identity-focused tactics such as voice phishing (vishing), device code phishing, and multi-factor authentication (MFA) abuse to steal data from SharePoint environments. [...]



Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/new-helix-vishing-group-emerges-in-sharepoint-data-theft-attacks/>

### 03. How World Cup crypto prediction sites take your money

Crypto prediction games promise easy wins, but some are little more than token sales or outright scams. Here's what to look for.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/how-world-cup-crypto-prediction-sites-take-your-money>

### 04. ThreatsDay: Cloud Bucket Hijacking, Windows LPE Chain, Global Fraud Bust + 17 More Stories

Most security mess starts as admin work. A link gets clicked. A tool gets trusted. A bucket name gets reused. A setting stays loose because nobody wants to touch it. This week is full of that kind of damage. Not loud. Not clever. Just small gaps doing big jobs. The worst part is how normal it all looks until the bill arrives. The full ThreatsDay list is bel...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/07/threatsday-cloud-bucket-hijacking.html>

### 05. 6.9 million driver's license numbers stolen from AssuranceAmerica

Millions of AssuranceAmerica customers are being notified after attackers accessed driver's license numbers and other personal information.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/data-breaches/2026/07/6-9-million-drivers-license-numbers-stolen-from-assuranceamerica>

### 06. Extortion crew hijacks Microsoft 365 accounts via fake passkey setup

The Pink cyber extortion crew is tricking employees into giving them access to their Microsoft 365 accounts by faking Entra passkey enrollment requests. The attack starts with a vishing call to an employee. The caller poses as IT and says it's time to set up a passkey. Everything after that is theater, built to keep the victim occupied



while the...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/09/microsoft-365-fake-passkey-setup-enrollment/>

## 07. Chinese-Funded Interpol Cybercrime Crackdown Leads to 5,800 Arrests

Operation First Light 2026, coordinated by Interpol and funded by the Chinese government, has led to 5,811 arrests

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/china-interpol-cybercrime-crackdown/>

## 08. 5,811 arrests, \$293 million seized over social engineering scams

Criminals who pose as police officers, romantic partners, and business suppliers have built fraud operations that reach across continents. A four-month enforcement campaign against these schemes wrapped up, and police in 97 countries and territories took part. Thousands of arrests The campaign, called Operation First Light 2026, centered on social engineeri...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/09/interpol-fraud-bust-social-engineering-scams/>

## 09. GodDamn Ransomware Uses PoisonX Driver to Disable Endpoint Defenses

Cybersecurity researchers have flagged a new ransomware family called GodDamn that employs the PoisonX kernel driver to neutralize security software as part of its defense evasion strategy. According to a new report published by the Threat Hunter Team from Symantec, the ransomware was first publicly spotted in the wild on May 21, 2026. It's assessed to be a...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://thehackernews.com/2026/07/goddamn-ransomware-uses-poisonx-driver.html>

## 10. Mount Royal University Confirms Data Stolen in Ransomware Attack

Hackers accessed the institution's internal network and deleted two drives containing employee, student, and university data. The post Mount Royal University Confirms Data

Stolen in Ransomware Attack appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.securityweek.com/mount-royal-university-confirms-data-stolen-in-ransomware-attack/>